Hvorfor trenger vi metoder for å skaffe oss oversikt over hvilke sårbarheter vi har?

I mai 2023 ble dansk energiinfrastruktur utsatt for et stort, samtidig, koordinert og vellykket dataangrep mot 22 selskaper. Angriperne oppnådde tilgang til noen av selskapenes industrielle kontrollsystemer og flere av dem måtte gå i øydrift for å opprettholde et nivå av kontroll over elektrisitetsforsyningen.

Angrepet utnyttet en spesifikk sårbarhet i selskapenes nettverksinfrastruktur, nærmere bestemt brannmurer fra produsenten Zyxel. Sårbarheten var identifisert og kommunisert av både produsenten og varslet av det danske SektorCert, men var ikke utbedret (patchet) av selskapene.

I SektorCerts gjennomgang[1] av angrepet kobles de utnyttede sårbarhetene blant til

- Manglende oversikt over enheter i nettverket, og dermed mangelfull sikkerhetsoppdatering av enheter, skapte veien inn for angriperen. Angriperen visste hvor sårbarheten var, hvem som var sårbare og hvordan de skulle utnytte den.
- Logging – angriperne må ha beveget seg inne i nettverket "under radaren" til SOC/CERT-funksjoner. Bedre oversikt over enheter og bedre logging og analyse ville økt sannsynligheten for å oppdage angrepet tidligere.
- Segmentering (oppdeling) av nettverk – bedre oppdeling mellom og innenfor sikkerhetssoner ville gitt økt tid og økte muligheter for å stoppe angriperen etter at fotfeste i nettverket var etablert.

Lignende anbefalinger finner vi også i ENISAs omfattende gjennomgang av angrep i EU mellom juni 2023 og juni 2024.[2]

Dette er eksempler på at en angriper raskt utnytter nulldagssårbarheter i nettverksinfrastruktur og at angriperne gjerne er raskere med å utnytte sårbarheten enn det virksomhetene klarer i arbeidet med å eliminere den.

I tillegg vil det finn es andre, og kanskje mindre sårbarheter på andre områder enn fysisk nettverksutstyr. Det kan være sårbarheter i virksomhetens styring av identiteter som kan gi angriperen mulighet til å gi seg selv forhøyede rettigheter. Det kan også være svakheter i logging som betyr at aktivitet ikke vil oppdages av SOC-funksjoner. Det kan i det hele tatt være en lang rekke store og små forhold som kan være akkurat det en angriper trenger for å komme seg inn i en virksomhets systemer, bevege seg gjennom og å komme seg ut med informasjon som er kritisk for virksomheten.

Figur 1. Langsiktig etterretning om sårbarheter. (Kilde, NSM)

I posisjon for sabotasje mot kritisk infrastruktur

Amerikanske myndigheter delte i 2024 at kinesiske, statssponsede aktører hadde tatt seg inn i datasystemene til kritisk infrastruktur i sektorer som energi, transport og vannforsyning. Myndighetene advarte om at aktørene forsøkte å posisjonere seg i systemene for å kunne angripe på et senere tidspunkt, for eksempel i tilfelle konflikt med USA. Teknikkene er sofistikerte og krever betydelig kompetanse. Samtidig er de vanskelige å oppdage, og trusselaktørene kan derfor oppholde seg i nettverkene over tid.

Aktøren Volt Typhoon skal ha klart å opprettholde tilgang til et nettverk over minst fem år ved å bruke såkalte Living-off-the-Land-teknikker. Teknikkene bruker programvarer og funksjoner allerede tilgjengelig på systemet for å gjennomføre ondsinnede handlinger. Angripere bruker teknikkene til å sanke inn verktøy på målets systemer, slik som komponenter i operativsystem eller installerte programvarer. Det er viktig å overvåke systemene til kritisk infrastruktur for å kunne avdekke uvanlig eller mistenkelig aktivitet.

Dette kan være informasjon som en angriper skaffer seg gjennom å ha fått fotfeste på innsiden av en virksomhets digitale infrastruktur. En angriper kan være på innsiden over lang tid (se eksempel i tekstboks), kun for å samle informasjon som kan brukes som våpen på et senere tidspunkt.

---

[1] SektorCERT-Angrebet-mod-dansk-kritisk-infrastruktur-TLP-CLEAR.pdf

[2] Se rapporten *ENISA Threat landscape 2024*

Det å kjenne til hva man har av hardware, software og informasjon, og hvilke sårbarheter som foreligger i sikringen av dem, er med andre ord grunnplanken i å skape god sikkerhet. Hvis store og små virksomheter i norsk kraftsektor kan få "lavterskel" verktøy for å få bedre oversikt over egne sårbarheter, vil det utgjøre en stor forskjell. Ikke bare for sikker strømforsyning, men for et sikkert samfunn i en usikker tid.